

Security Assessment Report (SAR)

Orion Citizen Services Platform (OCSP)

Organization: Orion Government Solutions
System ID: OCSP-001
Document Version: 1.0
Document Status: Draft for Review
Assessment Type: Initial / Periodic Security Control Assessment
Assessment Period: July–August 2026
Assessment Lead: Independent Security Assessor
Prepared By: Independent Security Assessor
GRC Support: Junior GRC Analyst
System Owner: Director of Government Platforms
Environment: Hybrid Cloud / Azure Government / Microsoft 365
Date: August 2026

Document Control

Version	Date	Author	Description	Status
1.0	August 2026	Independent Security Assessor	Initial Security Assessment Report	Draft for Review

Approval and Review

Role	Name	Status
Independent Security Assessor	Assigned Assessor	Pending
System Owner	Director of Government Platforms	Pending
Information System Security Officer	Assigned Security Officer	Pending
Chief Information Security Officer	CISO	Pending
Authorizing Official	Designated Authorizing Official	Pending

1. Executive Summary

An assessment of selected security controls implemented within the Orion Citizen Services Platform was conducted during July–August 2026.

The assessment was performed in accordance with the approved Security Assessment Plan and evaluated whether selected security controls were:

- Implemented as documented;
- Operating as intended; and
- Producing the desired security outcomes.

The assessment covered administrative, technical, and operational security controls supporting the Orion Citizen Services Platform.

The assessment used the following methods:

- Examination of documentation and evidence;
- Interviews with responsible personnel; and
- Technical and operational testing where appropriate.

The assessment identified several controls that were operating effectively. However, weaknesses were also identified in account lifecycle management, configuration baseline documentation, incident response exercise evidence, and third-party vendor reassessment activities.

The identified weaknesses require remediation and will be tracked through the Orion Citizen Services Platform Plan of Action and Milestones.

2. Overall Assessment Conclusion

Based on the evidence reviewed and assessment procedures performed, the assessment team determined that the Orion Citizen Services Platform has implemented a substantial portion of its assessed security controls.

However, several controls were determined to be **Other Than Satisfied** due to weaknesses in implementation consistency, documentation, testing evidence, or ongoing monitoring.

The assessment identified the following:

Result	Number of Controls
Satisfied	14
Other Than Satisfied	4
Not Applicable	0
Total Assessed	18

The assessment did not identify evidence indicating that the identified weaknesses had resulted in a confirmed security incident.

However, the weaknesses increase the potential risk of:

- Unauthorized access;
- Inconsistent system configuration;
- Delayed incident response readiness; and
- Increased exposure through third-party dependencies.

The identified findings should be entered into the system POA&M and remediated according to their assigned priority.

3. System Under Assessment

3.1 System Identification

Attribute	Description
System Name	Orion Citizen Services Platform
System Acronym	OCSP
System ID	OCSP-001
Organization	Orion Government Solutions
System Type	Hybrid Cloud Information System
Primary Cloud Environment	Azure Government
Supporting Platform	Microsoft 365
System Owner	Director of Government Platforms
Primary Function	Government and citizen service operations

3.2 System Description

The Orion Citizen Services Platform supports government-related service operations involving customer and citizen information.

The system operates across a hybrid environment consisting of:

- Azure Government-hosted workloads;
- Application services;
- Databases and storage;
- Identity and authentication services;
- Security monitoring capabilities;
- Corporate support systems;
- Remote workforce access; and

- Approved third-party services and external system connections.

The system processes sensitive information and operates within a regulated environment.

4. Assessment Scope

The assessment included selected security controls supporting:

- Access control;
- Awareness and training;
- Audit and accountability;
- Assessment and monitoring;
- Configuration management;
- Contingency planning;
- Identification and authentication;
- Incident response;
- Maintenance;
- Media protection;
- Physical and environmental protection;
- Planning;
- Personnel security;
- Risk assessment;
- System and services acquisition;
- System and communications protection;
- System and information integrity; and
- Supply chain risk management.

The assessment focused on controls within the OCSP authorization boundary and relevant supporting services.

5. Assessment Methodology

The assessment was conducted using the following methods.

5.1 Examine

The assessment team reviewed:

- Security policies;
- Procedures;

- System Security Plan;
 - Access records;
 - Configuration documentation;
 - Audit logs;
 - Vulnerability reports;
 - Incident response documentation;
 - Training records;
 - Vendor assessments;
 - Change management records; and
 - Other supporting evidence.
-

5.2 Interview

Interviews were conducted with personnel responsible for:

- System ownership;
 - Information security;
 - Governance, risk, and compliance;
 - Identity and access management;
 - Infrastructure;
 - Security operations;
 - Incident response;
 - Human resources; and
 - Vendor risk management.
-

5.3 Test

Testing activities included:

- Review of selected user accounts;
- Review of privileged access;
- MFA enforcement validation;
- Audit logging validation;
- Configuration management review;
- Review of vulnerability remediation;
- Review of incident response exercise evidence; and
- Review of vendor security assessment records.

Testing was performed in a manner intended to minimize disruption to production operations.

6. Assessment Limitations

The following limitations applied during the assessment:

1. Certain cloud infrastructure controls were evaluated through available provider assurance documentation because the organization does not directly operate the underlying cloud infrastructure.
 2. Third-party security controls were assessed based on available contractual, assessment, and assurance documentation.
 3. The assessment did not include destructive testing or activities designed to intentionally disrupt production services.
 4. Assessment conclusions were based on the evidence and information available during the assessment period.
 5. The assessment represents a point-in-time evaluation and does not guarantee that control effectiveness will remain unchanged after the assessment period.
-

7. Assessment Results Summary

Control Area	Result	Finding
Access Control	Other Than Satisfied	AC-2 — Account lifecycle management was inconsistently performed
Awareness and Training	Satisfied	No significant deficiency identified
Audit and Accountability	Satisfied	Logging and monitoring capabilities were implemented
Assessment and Monitoring	Satisfied	Assessment and tracking processes were established
Configuration Management	Other Than Satisfied	CM-2 — Configuration baseline documentation was incomplete
Contingency Planning	Satisfied	Backup and recovery capabilities were documented
Identification and Authentication	Satisfied	MFA and centralized authentication were implemented
Incident Response	Other Than Satisfied	IR-3 — Incident response exercise evidence was outdated
Maintenance	Satisfied	Maintenance activities were appropriately controlled
Media Protection	Satisfied	Media protection processes were documented
Physical Protection	Satisfied	Applicable physical protections were established
Planning	Satisfied	System security planning documentation was maintained

Control Area	Result	Finding
Personnel Security	Satisfied	Personnel lifecycle procedures were established
Risk Assessment	Satisfied	Risk assessment activities were documented
System and Services Acquisition	Satisfied	Security requirements were incorporated into acquisition activities
System and Communications Protection	Satisfied	Communications protections were implemented
System and Information Integrity	Satisfied	Vulnerability and integrity management processes were operating
Supply Chain Risk Management	Other Than Satisfied	SR-3 — Critical vendor reassessment activities were not completed on schedule

8. Detailed Assessment Findings

Finding SAR-OCSP-001

Control

AC-2 — Account Management

Assessment Result

Other Than Satisfied

Finding Title

Inactive accounts were not consistently disabled within the defined organizational timeframe.

Condition

Review of account management records identified instances where inactive user accounts remained enabled beyond the organization's defined account lifecycle requirements.

The account management process relied partially on manual review and did not consistently ensure timely identification and disabling of inactive accounts.

Evidence Reviewed

The assessment team reviewed:

- User account listings;
- Account management procedures;
- Periodic access review records;
- Account termination records; and
- Identity management reports.

Relevant evidence references included:

EVD-AC-001 – Periodic Access Review
EVD-AC-002 – Role-Permission Matrix
EVD-AC-004 – Account Termination Records

Risk

Active accounts that are no longer required may provide unnecessary opportunities for unauthorized access.

If credentials associated with an unnecessary account are compromised, an attacker may be able to use the account to access system resources.

Potential Impact

Potential impacts include:

- Unauthorized access;
 - Increased attack surface;
 - Delayed account deprovisioning;
 - Increased risk of credential misuse.
-

Recommendation

Orion Government Solutions should strengthen account lifecycle management by:

1. Defining clear inactive account criteria;

2. Implementing automated or consistently monitored account identification;
 3. Establishing a documented disablement workflow;
 4. Assigning clear ownership for inactive account review;
 5. Performing periodic validation; and
 6. Maintaining evidence of account disablement activities.
-

Responsible Owner

Identity and Access Management Team

POA&M Reference

POAM-001

Finding SAR-OCSP-002

Control

CM-2 — Baseline Configuration

Assessment Result

Other Than Satisfied

Finding Title

Configuration baseline documentation was incomplete for selected system components.

Condition

The assessment identified that configuration baseline documentation was not consistently maintained for all system components within the assessment scope.

Although technical configuration standards existed for selected components, baseline documentation was incomplete or not consistently linked to the relevant system components.

Evidence Reviewed

The assessment team reviewed:

- Configuration management policy;
- Configuration documentation;
- Change management records;
- System configuration information.

Relevant evidence references included:

EVD-CM-001 – Approved Configuration Baseline
EVD-CM-002 – Change Management Records
EVD-CM-003 – Configuration Review Report

Risk

Incomplete configuration baselines may make it more difficult to:

- Identify unauthorized changes;
 - Detect configuration drift;
 - Maintain consistent security settings;
 - Validate system security posture.
-

Potential Impact

Potential impacts include:

- Increased configuration drift;
 - Inconsistent security settings;
 - Delayed detection of unauthorized changes;
 - Increased vulnerability exposure.
-

Recommendation

Orion Government Solutions should establish and maintain complete configuration baselines for applicable OCSF components.

The organization should:

1. Identify all components requiring baselines;
 2. Document approved configurations;
 3. Assign baseline owners;
 4. Establish a review frequency;
 5. Link configuration changes to change management records; and
 6. Periodically validate system configurations against approved baselines.
-

Responsible Owner

Infrastructure and Platform Engineering

POA&M Reference

POAM-002

Finding SAR-OCSP-003

Control

IR-3 — Incident Response Testing

Assessment Result

Other Than Satisfied

Finding Title

Evidence of a recent incident response exercise was not available.

Condition

The organization maintained incident response procedures; however, evidence of a recent exercise validating the effectiveness of those procedures was outdated.

The assessment team could not verify that all relevant personnel had recently participated in an exercise designed to validate incident response coordination and escalation procedures.

Evidence Reviewed

The assessment team reviewed:

- Incident response plan;
- Incident response procedures;
- Exercise documentation;
- Incident escalation procedures.

Relevant evidence references included:

EVD-IR-001 – Incident Response Plan
EVD-IR-002 – Incident Response Exercise Record
EVD-IR-004 – Incident Escalation Procedures

Risk

Without regular incident response exercises, the organization may not identify weaknesses in:

- Communication procedures;
 - Escalation paths;
 - Roles and responsibilities;
 - Decision-making processes;
 - Coordination between technical and business teams.
-

Potential Impact

Potential impacts include:

- Delayed incident response;
 - Ineffective escalation;
 - Confusion regarding responsibilities;
 - Increased operational impact during a security event.
-

Recommendation

Orion Government Solutions should conduct and document a current incident response exercise.

The exercise should:

1. Use a realistic scenario;
2. Include relevant stakeholders;
3. Test communication and escalation;
4. Document identified weaknesses;
5. Track improvement actions; and
6. Retain exercise evidence for future assessment activities.

Responsible Owner

Security Operations and Incident Response Team

POA&M Reference

POAM-003

Finding SAR-OCSP-004

Control

SR-3 — Supply Chain Controls and Processes

Assessment Result

Other Than Satisfied

Finding Title

Security reassessment of a critical third-party vendor was not completed according to the defined review schedule.

Condition

The assessment identified that a critical third-party service provider had not completed its scheduled security reassessment within the required review period.

The vendor remained an active dependency for system operations.

Evidence Reviewed

The assessment team reviewed:

- Vendor risk management procedures;
- Vendor security assessment records;
- Third-party security documentation;
- Vendor monitoring records.

Relevant evidence references included:

EVD-SR-001 – Vendor Risk Assessment
EVD-SR-003 – Contractual Security Requirements
EVD-SR-004 – Vendor Monitoring Records

Risk

Delayed reassessment of critical vendors may result in outdated understanding of:

- Vendor security posture;
 - Control effectiveness;
 - New vulnerabilities;
 - Changes to vendor services;
 - Changes to the vendor's risk profile.
-

Potential Impact

Potential impacts include:

- Increased third-party risk;
 - Delayed identification of vendor weaknesses;
 - Increased exposure through system dependencies.
-

Recommendation

Orion Government Solutions should establish a process to ensure that critical vendors are reassessed according to defined schedules.

The process should include:

1. Critical vendor identification;
 2. Defined reassessment frequency;
 3. Automated or centrally monitored review deadlines;
 4. Escalation of overdue assessments;
 5. Risk acceptance procedures for delayed reviews; and
 6. Documentation of completed reassessments.
-

Responsible Owner

Vendor Risk Management

POA&M Reference

POAM-004

9. Satisfied Control Summary

The following control areas were assessed as Satisfied:

Awareness and Training

Required security awareness and training processes were documented and evidence supported completion tracking.

Audit and Accountability

Audit logging and security monitoring capabilities were implemented and supported system accountability and security investigation activities.

Assessment and Monitoring

The organization maintained security assessment and risk tracking processes.

Contingency Planning

Backup and recovery capabilities were documented and evidence supported the existence of recovery activities.

Identification and Authentication

Centralized authentication and multi-factor authentication were implemented for applicable access scenarios.

Maintenance

Maintenance activities were controlled through documented processes and authorized personnel.

Media Protection

Media handling and protection requirements were documented.

Physical and Environmental Protection

Applicable physical protection responsibilities were established for Orion-managed facilities and supporting environments.

Planning

System security planning documentation was maintained through the SSP and related RMF documentation.

Personnel Security

Personnel lifecycle processes supported appropriate access authorization and removal activities.

Risk Assessment

Risk assessment and risk management processes were established.

System and Services Acquisition

Security requirements were considered in applicable acquisition and vendor management activities.

System and Communications Protection

Appropriate communications and network protection mechanisms were implemented.

System and Information Integrity

Vulnerability management, patching, endpoint protection, and security monitoring processes were established.

10. Risk Summary

The assessment identified four weaknesses requiring remediation.

Finding ID	Control	Risk Area	Priority
SAR-OCSP-001	AC-2	Account Lifecycle Management	High
SAR-OCSP-002	CM-2	Configuration Management	Medium
SAR-OCSP-003	IR-3	Incident Response Readiness	Medium
SAR-OCSP-004	SR-3	Third-Party Risk	Medium

The account lifecycle management weakness was assigned the highest priority because unnecessary active accounts may directly increase the risk of unauthorized system access.

The remaining findings require timely remediation due to their potential impact on configuration consistency, incident response readiness, and third-party risk visibility.

11. Recommended Remediation Priorities

High Priority

SAR-OCSP-001 — Account Lifecycle Management

Recommended action:

- Improve inactive account identification;
- Automate account lifecycle processes where practical;
- Establish consistent disablement procedures.

Medium Priority

SAR-OCSP-002 — Configuration Baselines

Recommended action:

- Complete configuration baseline documentation;
- Establish baseline ownership;
- Perform periodic configuration validation.

SAR-OCSP-003 — Incident Response Exercise

Recommended action:

- Conduct a current incident response exercise;
- Document results;
- Track improvement actions.

SAR-OCSP-004 — Vendor Reassessment

Recommended action:

- Complete the overdue critical vendor reassessment;
- Implement tracking and escalation for future reassessments.

12. POA&M Integration

The following findings must be entered into the Orion Citizen Services Platform POA&M:

SAR Finding	POA&M ID	Status
SAR-OCSP-001	POAM-001	Open
SAR-OCSP-002	POAM-002	Open
SAR-OCSP-003	POAM-003	Open
SAR-OCSP-004	POAM-004	Open

The POA&M must track:

- Weakness description;
- Risk;

- Remediation actions;
- Responsible owner;
- Milestones;
- Target completion date;
- Status;
- Completion evidence;
- Validation results.

13. Assessment Traceability

The following traceability chain is maintained:

```
System Security Plan
      |
      v
Security Assessment Plan
      |
      v
Assessment Procedures
      |
      v
Evidence Review
      |
      v
Assessment Results
      |
      v
Security Assessment Report
      |
      v
Findings
      |
      v
POA&M
      |
      v
Remediation
      |
      v
Reassessment
      |
      v
Finding Closure
```

Example:

```
AC-2
  |
  v
SSP:
```

Accounts are managed through documented lifecycle procedures.

|

v

SAP:

Review account lifecycle and inactive account management.

|

v

Evidence:

EVD-AC-001

|

v

SAR:

Inactive accounts were not consistently disabled.

|

v

POA&M:

POAM-001

|

v

Remediation:

Improve and automate account lifecycle management.

14. Assessment Conclusion

The assessment determined that the Orion Citizen Services Platform has established a broad set of security controls supporting the confidentiality, integrity, and availability of system information and services.

The assessment also identified four weaknesses requiring remediation.

The identified weaknesses do not eliminate the effectiveness of the overall security program but require appropriate corrective action and continued monitoring.

The System Owner and relevant control owners should address the identified findings through the Plan of Action and Milestones process.

Following remediation, appropriate controls should be reassessed to determine whether the identified weaknesses have been effectively addressed.

The final authorization decision remains the responsibility of the designated Authorizing Official.

15. Final Assessment Status

Overall Assessment Status: Remediation Required

Total Controls Assessed: 18

Satisfied: 14

Other Than Satisfied: 4

POA&M Required: Yes

Authorization Decision: To be determined by the Authorizing Official

16. Assessment Report Approval

Role	Name	Signature / Approval	Date
Independent Security Assessor	Assigned Assessor	Pending	Pending
System Owner	Director of Government Platforms	Pending	Pending
Information System Security Officer	Assigned Security Officer	Pending	Pending
Chief Information Security Officer	CISO	Pending	Pending
Authorizing Official	Designated Authorizing Official	Pending	Pending

Document Status

Document: Security Assessment Report

System: Orion Citizen Services Platform

System ID: OCSP-001

Version: 1.0

Status: Draft for Review

Next Related Document: Plan of Action and Milestones

Primary POA&M References: POAM-001 through POAM-004